Front Desk System - OWASP Security Evidence

DDP-183 | Issue #84 | Evidence update: 27 October 2026

Assessment scope

Checklist against OWASP Top 10 categories, based on reviewed repository tests and isolated local verification. Evidence demonstrates selected safeguards; it does not certify the whole hotel system, production configuration, independent vulnerability testing or centralized authentication.

Dependency audit correction

The former A06 HIGH finding from the frontend development dependency undici 8.11.2 was corrected to 8.12.2 on the QA branch (commit 1065617). Frontend CI run 40534533200 completed both full and production-only npm audits with zero vulnerabilities. Backend run 40530366600 also passed its audit. The default-branch Dependabot advisory remains a separate merge/recheck task; do not treat the current branch result as proof that default-branch alerts have cleared.

Category-by-category controls

A01 Broken Access Control

Status: PARTIALLY EVIDENCED

Evidence: JWT authorization, read/write RBAC, 401/403 E2E checks, invalid actor and real WKMS assignment permission tests.

Remaining verification: Complete endpoint-by-role matrix, negative authorization checks on every protected route, public staging review.

A02 Cryptographic Failures

Status: NOT FULLY VERIFIED

Evidence: JWT signature and issuer unit tests; local test-only JWTs used for evidence.

Remaining verification: Central identity password storage (bcrypt >=12), refresh-token controls, staging HTTPS/TLS and deployed secret handling.

A03 Injection

Status: PARTIALLY EVIDENCED

Evidence: PostgreSQL parameter binding, DTO validation, text sanitization tests.

Remaining verification: Targeted route-level injection and fuzzing review.

A04 Insecure Design

Status: NOT FULLY VERIFIED

Evidence: Database transaction rollback and append-only audit tests.

Remaining verification: Approved threat model, sign-off of cross-service trust/security design.

A05 Security Misconfiguration

Status: PARTIALLY EVIDENCED

Evidence: Joi production/staging configuration validation, DB_SYNC guard, origins checks, CI/Docker checks.

Remaining verification: Actual public staging configuration and error-disclosure testing.

A06 Vulnerable and Outdated Components

Status: REMEDIATED IN TESTED FEATURE BRANCH

Evidence: undici dev dependency upgraded to 8.12.2 in commit 1065617. Frontend CI full audit = 0 vulnerabilities; production-only = 0; backend CI audit = 0.

Remaining verification: Merge fix into default branch and recheck Dependabot alert #24 and independent supply-chain risks.

A07 Identification and Authentication Failures

Status: PARTIALLY EVIDENCED

Evidence: Bad/expired/wrong-issuer JWT rejection tested; Socket.IO authentication checks.

Remaining verification: Central Auth login, session rotation, account lockout, rate limits with live identity provider.

A08 Software and Data Integrity Failures

Status: PARTIALLY EVIDENCED

Evidence: npm ci, lockfiles, append-only audit trigger with PostgreSQL tests; protected GitHub CI.

Remaining verification: Signed release artifacts, provenance and production deployment integrity review.

A09 Security Logging and Monitoring Failures

Status: PARTIALLY EVIDENCED

Evidence: Audit records for check-in, room updates, assignments; redacting logger and append-only DB.

Remaining verification: Staging alerting/monitoring, logs for authentication failures and actual retention.

A10 Server-Side Request Forgery

Status: NOT FULLY VERIFIED

Evidence: WKMS outbound HTTP integration uses configured service URL, with local secured assignment integration verification.

Remaining verification: Outbound URL allowlist and SSRF negative tests in deployed environment.

Local cross-service findings

• Phase B showed actual WKMS checkout consumer persistence, duplicate checkout event handling and escalation outbox interoperability on disposable infrastructure.

• Phase C validated broker restart and FDS/WKMS consumer reconnection; Phase D validated a development browser fallback/reconnect experience.

• W04-B validated a real local authenticated manual assignment and audit persistence. Upstream repeated-assignment conflict was surfaced to FDS as HTTP 502 rather than the source 409; normalization remains a review item.

• W04-B service-task creation and worker discovery endpoints remain blocked; local tests do not prove internet-facing staging integration.

Security verdict

A06 vulnerable-component finding: mitigated in tested feature branch with zero CI audit findings. Other Top 10 categories: partial or unverified as identified above. No overall OWASP compliance or penetration-test clearance is claimed.

Evidence references

Backend: https://github.com/forever-hotel/front-desk/actions/runs/40530366600

Frontend: https://github.com/forever-hotel/front-desk/actions/runs/40534533200

Further local evidence: evidence/fds-core-acceptance/verification.md; evidence/fds-messaging-realtime/*-verification.md; evidence/fds-messaging-realtime/w04b-live-assignment-*/verification.md.